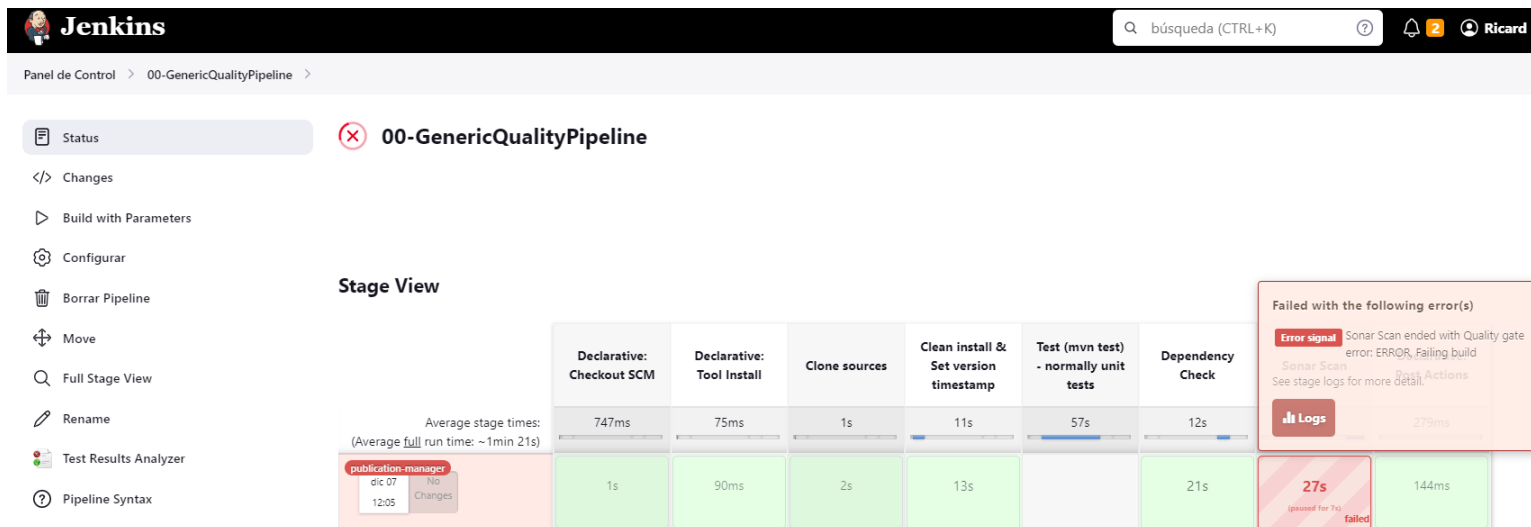


Sonarqube vulnerability analysis

Sonarqube analysis will be triggered always when executing the Jenkins pipelines jobs. In Both:

- **Build pipelines:** used to compile, test, run a sonar scan and only build and publish the project if successful. Later this same built package can be deployed into the different environments for testing (INT, UAT) and later PROD.

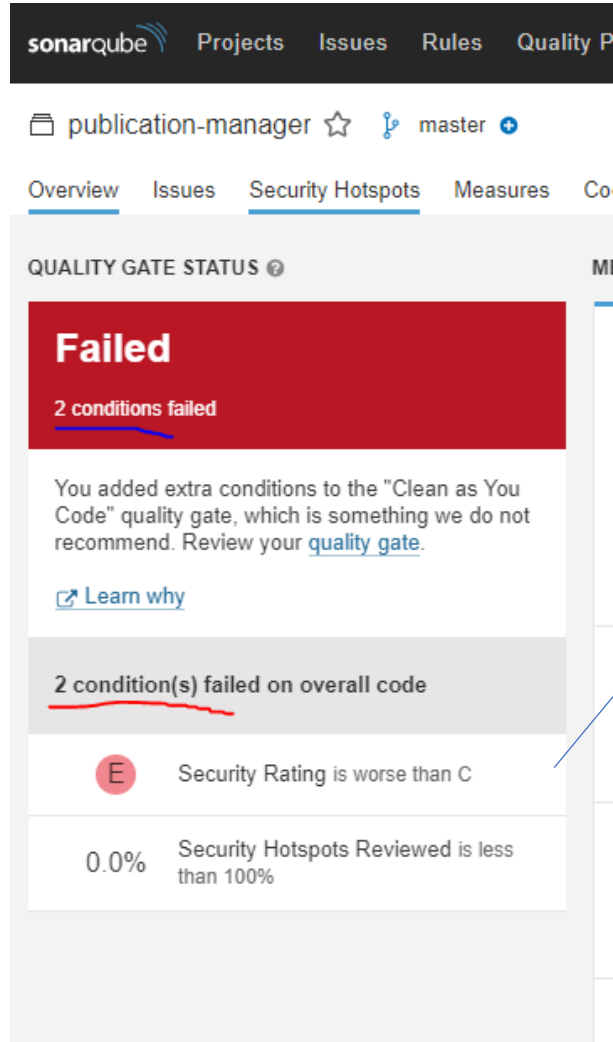
- **Quality pipelines:** To not build but to perform a compilation and unit test run along with a Sonarqube analysis of a desired branch. Often used by developers to scan new added code for vulnerabilities before merging feature branches to the master (main branch of source code)



If the sonar scan stage fails with this message **Quality gate ERROR**

Means sonar has failed the quality gate. Then next step is checking the sonar analysis

Sonarqube vulnerability analysis 2

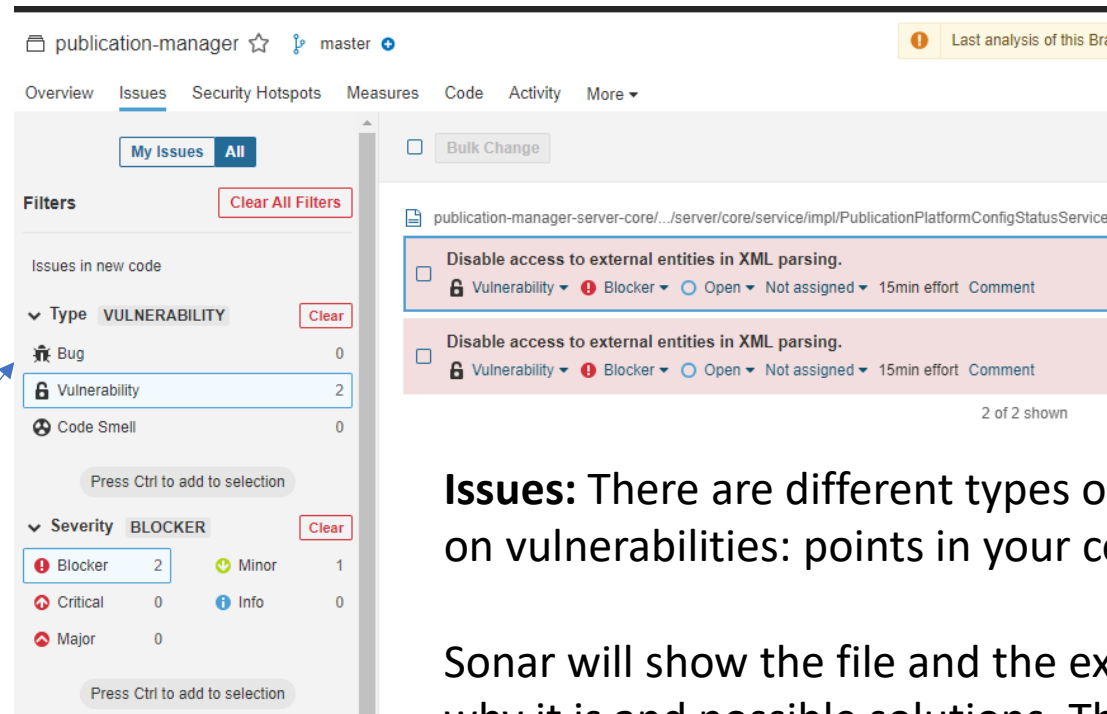


The screenshot shows the Sonarqube Quality Gate Status for the 'publication-manager' project. The status is 'Failed' with a red banner. Below the banner, it states '2 conditions failed' and provides a message: 'You added extra conditions to the "Clean as You Code" quality gate, which is something we do not recommend. Review your [quality gate](#).' A link 'Learn why' is provided. Below this, it shows '2 condition(s) failed on overall code'. The failed conditions are listed as follows:

Condition	Value
Security Rating is worse than C	E
Security Hotspots Reviewed is less than 100%	0.0%

Once the project that has the quality gate failed is found, first step is to check the reason.

In this case: Security Rating is worse than C (is E) and Security hotspots are not 100% reviewed (are 0%). Clicking in each failed condition will show why.



The screenshot shows the Sonarqube Issues page for the 'publication-manager' project. The 'Issues' tab is selected. The 'Filters' section shows 'Type: VULNERABILITY' and 'Severity: BLOCKER'. The 'Issues in new code' table shows 2 vulnerabilities of type 'Vulnerability' and severity 'Blocker'. The 'Bulk Change' button is visible. The 'Issues' table shows 2 of 2 shown.

Type	Count
Bug	0
Vulnerability	2
Code Smell	0

Severity	Count
Blocker	2
Minor	1
Critical	0
Info	0
Major	0

There are also vulnerabilities that can come from external dependencies. They will show here too. But not link to a line of code.

Issues: There are different types of issues but we are focusing on vulnerabilities: points in your code that are open to attack.

Sonar will show the file and the exact line that is problematic, why it is and possible solutions. These should be fixed ASAP with the code changes and launch a build again and ensure they don't appear on next analysis

sonarqube Projects Issues Rules Quality P

[Overview](#) [Issues](#) [Security Hotspots](#) [Measures](#) [Co](#)

Failed

2 conditions failed

[🔗 Learn why](#)

E Security Rating is worse than C

Overview Issues **Security Hotspots** Measures Code Activity More ▾

5 Security Hotspots to review

Delivering code in production with debug features activated is security-sensitive [java:S4507](#)

This security hotspot needs to be reviewed to assess whether the code poses a risk. [Change status](#)

Make sure this debug feature is deactivated before delivering the code in production.	Where is the risk?	What's the risk?	Assess the risk	How can I fix it?

Make sure this debug feature is deactivated before delivering the code in production.

```
111 String responseBodyAsString = post.getResponseBodyAsString();
112 AWSErrorResponse error = unmarshallAWSError(responseBodyAsString);
```

...vice/impl/PublicationServerService.java

```
119         e.printStackTrace();
```

```

#Returns some Able data frame features in
    170
    Creating ErrorMessage = ""

```

review. Upon review, you'll either find there is no threat or you

the code. This is reviewed manually in the SonarQube UI. Or

<https://docs.sonarsource.com/sonarqube/9.9/user-guide/security-hotspots/#what-is-a-security-hotspot>

A security hotspot highlights a security-sensitive piece of code that the developer needs to review. Upon review, you'll either find there is no threat or you need to apply a fix to secure the code. This is reviewed manually in the SonarQube UI. Once reviewed the quality gate should pass.